Nesting is for the birds: The problem with nested groups

trimarcsecurity.com/hub-post/nesting-is-for-the-birds-the-problem-with-nested-groups

Jake Hildreth March 12, 2024

Updated: Dec 13, 2024



Nesting is for birds, not Admin Groups

Today, I sat in on a report review for a Trimarc Active Directory Security Assessment (ADSA) for a typical customer environment. It had a couple thousand users, some domain controllers, some group policy objects, etc. And like almost every customer I've interacted with in the last 2+ years at Trimarc, they had a couple of Critical issues.

Critical issues can be very fun to describe, but that's not what we're talking about today. Instead, we'll talk about a common High priority issue: excessive membership in Active Directory administration (AD Admin) groups due to <insert scary music> *Nested Groups*! More than 2% of this customer's staff had AD Admin privileges because of nested groups.

"What's a nested group?", you ask?

First, some background.

For the purposes of this blog, Active Directory (AD) is a Windows-based identity management platform. (AD is so much more, but that's the core.) AD tracks users' identities and permissions in a Windows-based environment.

In AD, the basic identity types are users, computers, and service accounts. Users, computers, and service accounts can be grouped together in groups - what a shocker! - to make administration more consistent and reliable. We love a well-designed group at Trimarc!

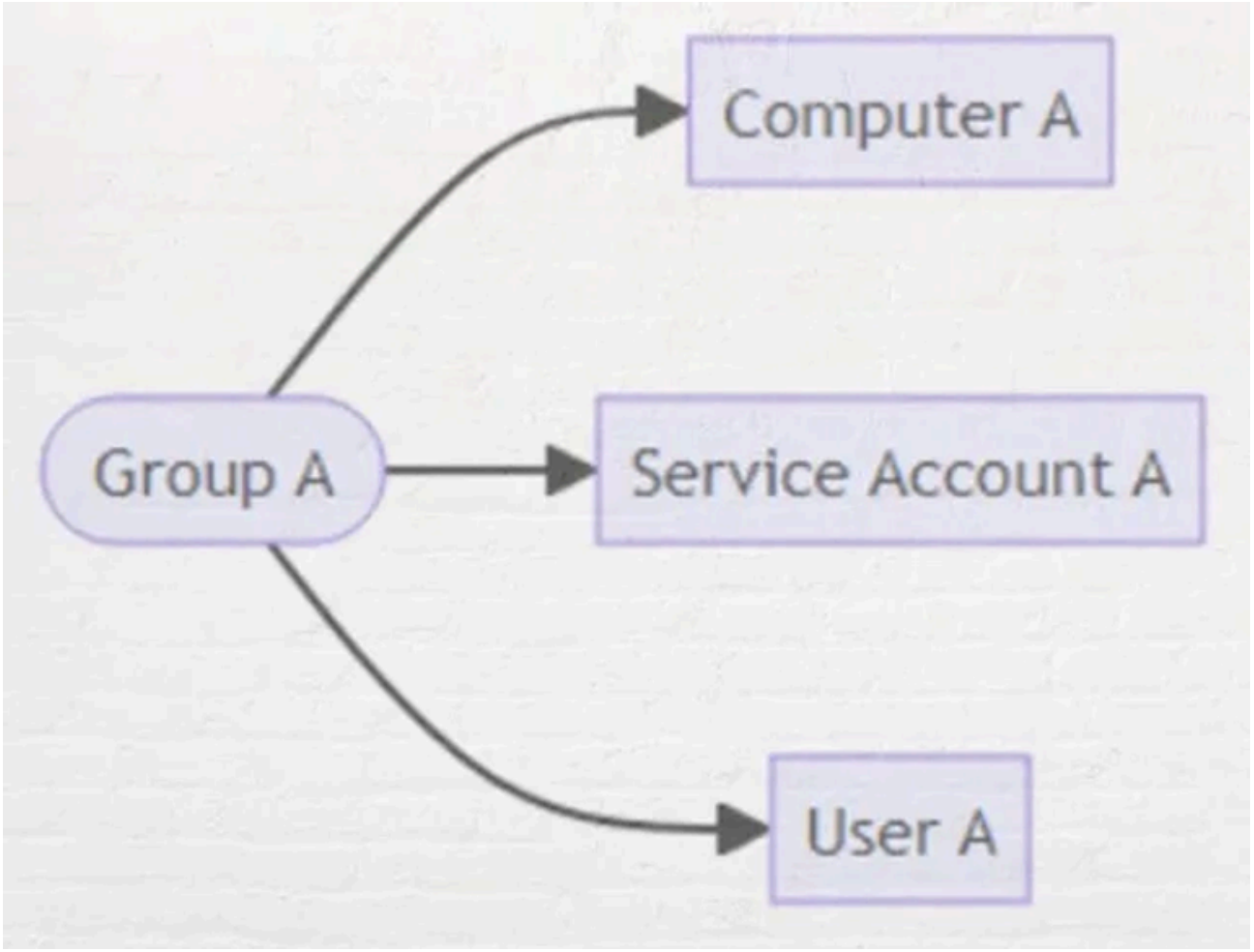


Figure 1 - A normal group

But a "fun" thing Microsoft decided to do with groups was to allow groups to be members of other groups. i.e., Group B can be a member of Group A. In this case, Group B gains any rights and privileges granted to Group A. This can be particularly useful in certain administration methodologies.

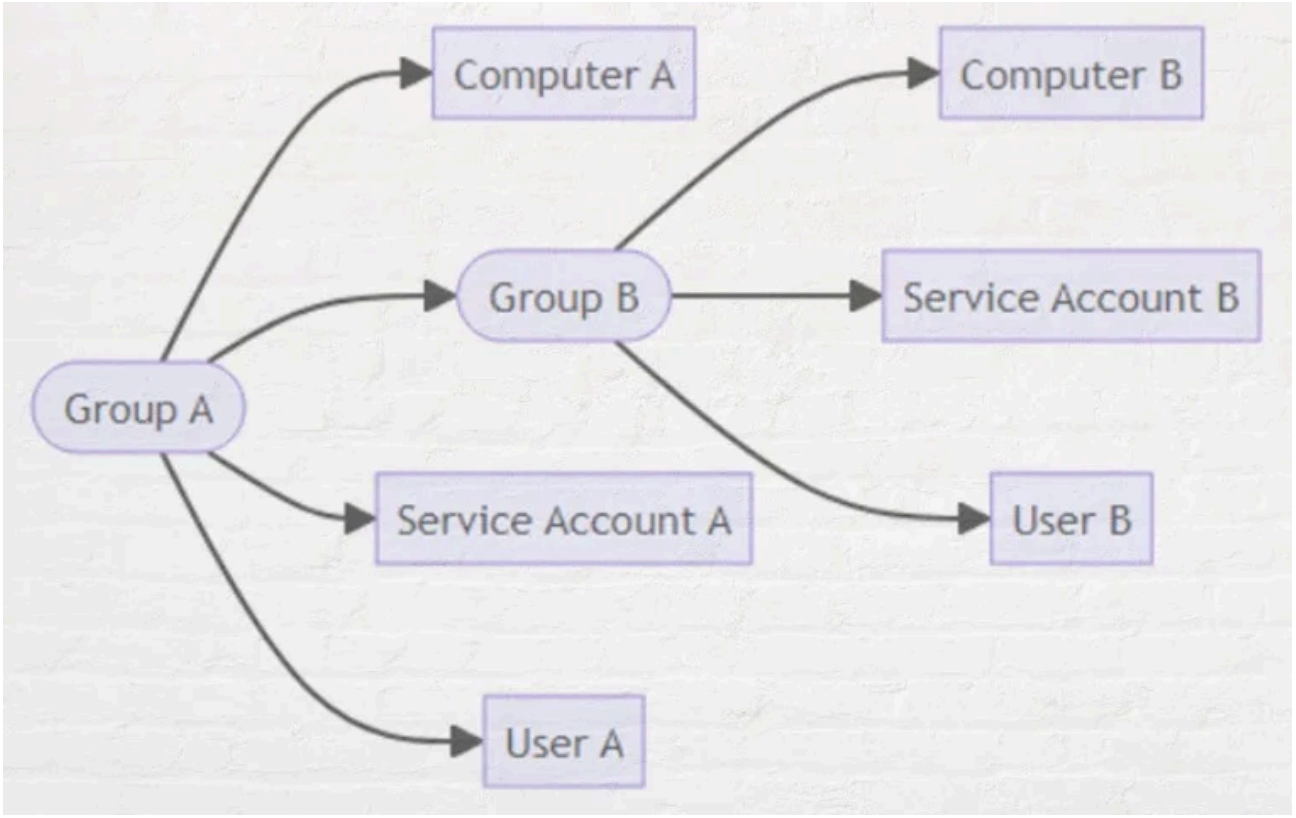


Figure 2 - A nested group (please don't do this in AD Admin groups)

One problem that immediately arises is "circular" nesting. This occurs when Group B is a member of Group A, and Group A is also a member of Group B. As in the previous paragraph, Group B now inherits Group A's rights, but now, Group A also inherits any rights granted to Group B. Again, this may be useful in your, uh, *unique* form of administration, but it's confusing and can grant unexpected rights to members of both groups.

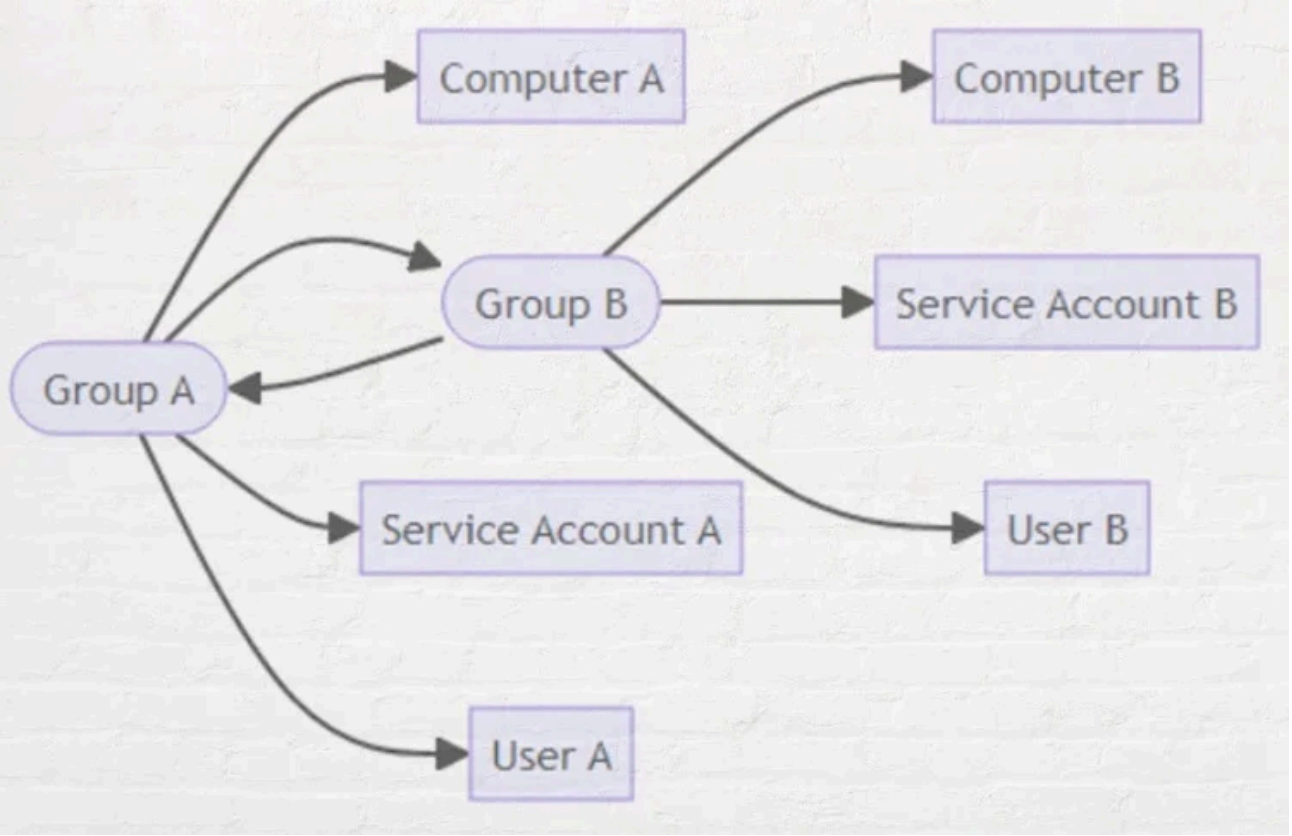


Figure 3 - Circular nesting (please don't do this ever)

However, the issue that affected this customer was more nefarious: nesting in AD Admin groups.

At Trimarc, we focus on the groups we call AD Admin groups. These are groups that are expected to do AD administration: built-in domain Administrators (BA), Domain Admins (DA), Enterprise Admins (EA), and Schema Admins (SA).

Unknowingly, the customer unintentionally added 2 groups containing regular user accounts to the DA group. The customer expected <10 AD Admins, but actually had almost 150. That's 140ish users that could misuse their unnecessary powers and cause havoc in the forest.

How did this happen?

Often, a department-level group (like "ITStaff") gets added to an AD Admin group (like "Domain Admins") when the company is smaller/newer. AD Administration is easy to understand when there is only one member on the IT team!

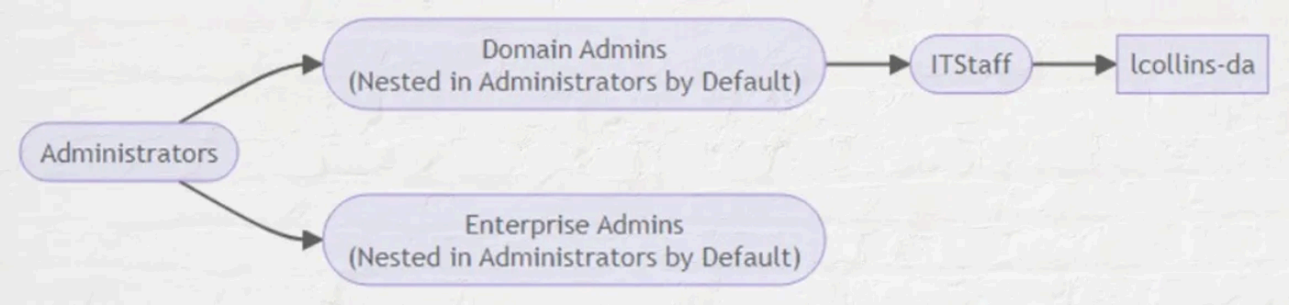


Figure 4 - lcollins will be burnt out if he doesn't get support soon.

But as the company grows, new IT folks get hired and are immediately added to the ITStaff group and receive DA privileges – whether they need to be DA or not.

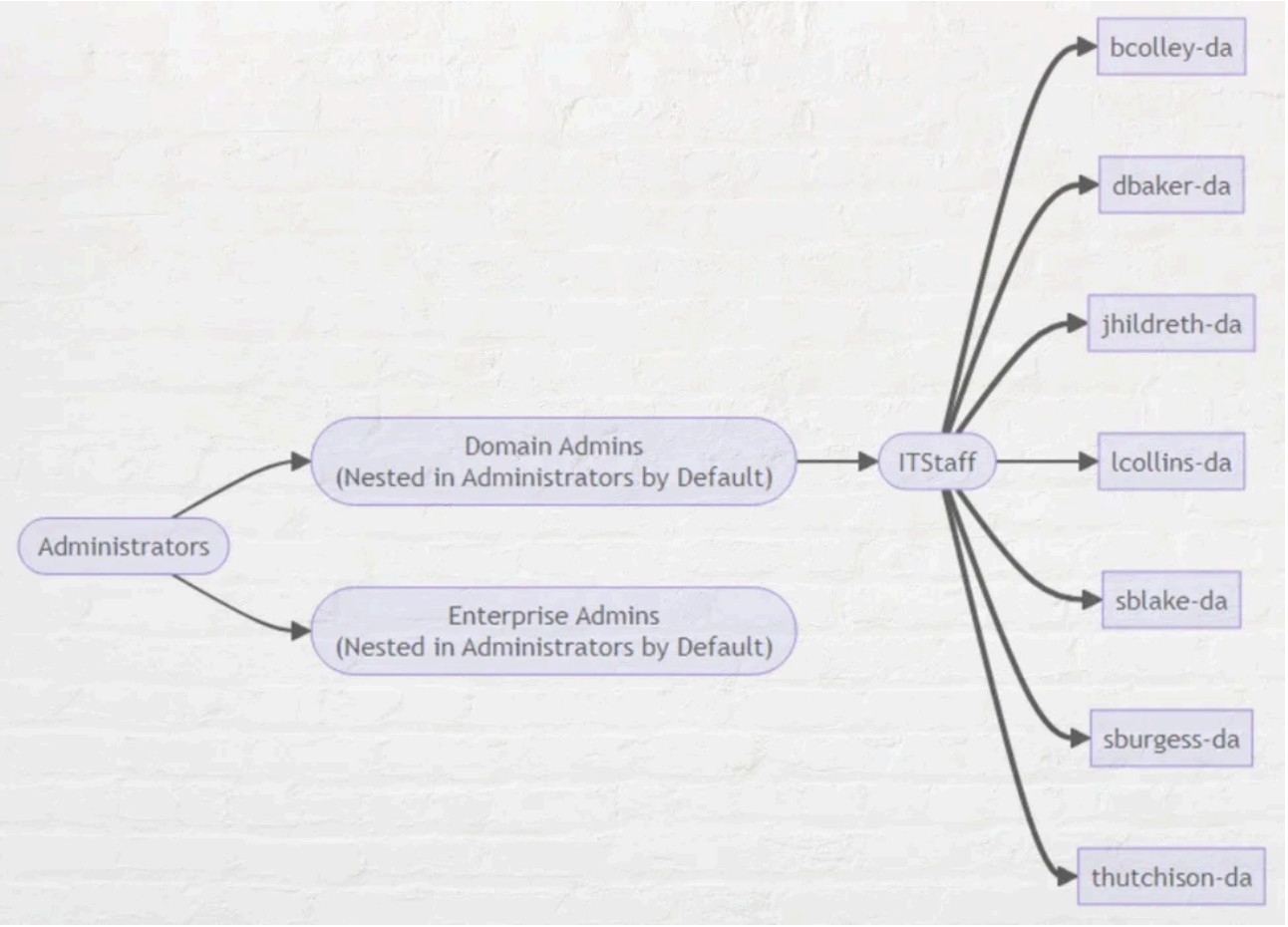


Figure 5 - Do you really trust all these yahoos to have DA?

At some point, the company hires a Managed Services Provider (MSP) to handle a subset of technology-related tasks. Since they're "IT", the MSP's user group gets added to the ITStaff group, and suddenly the DA ranks swell to untenable levels.

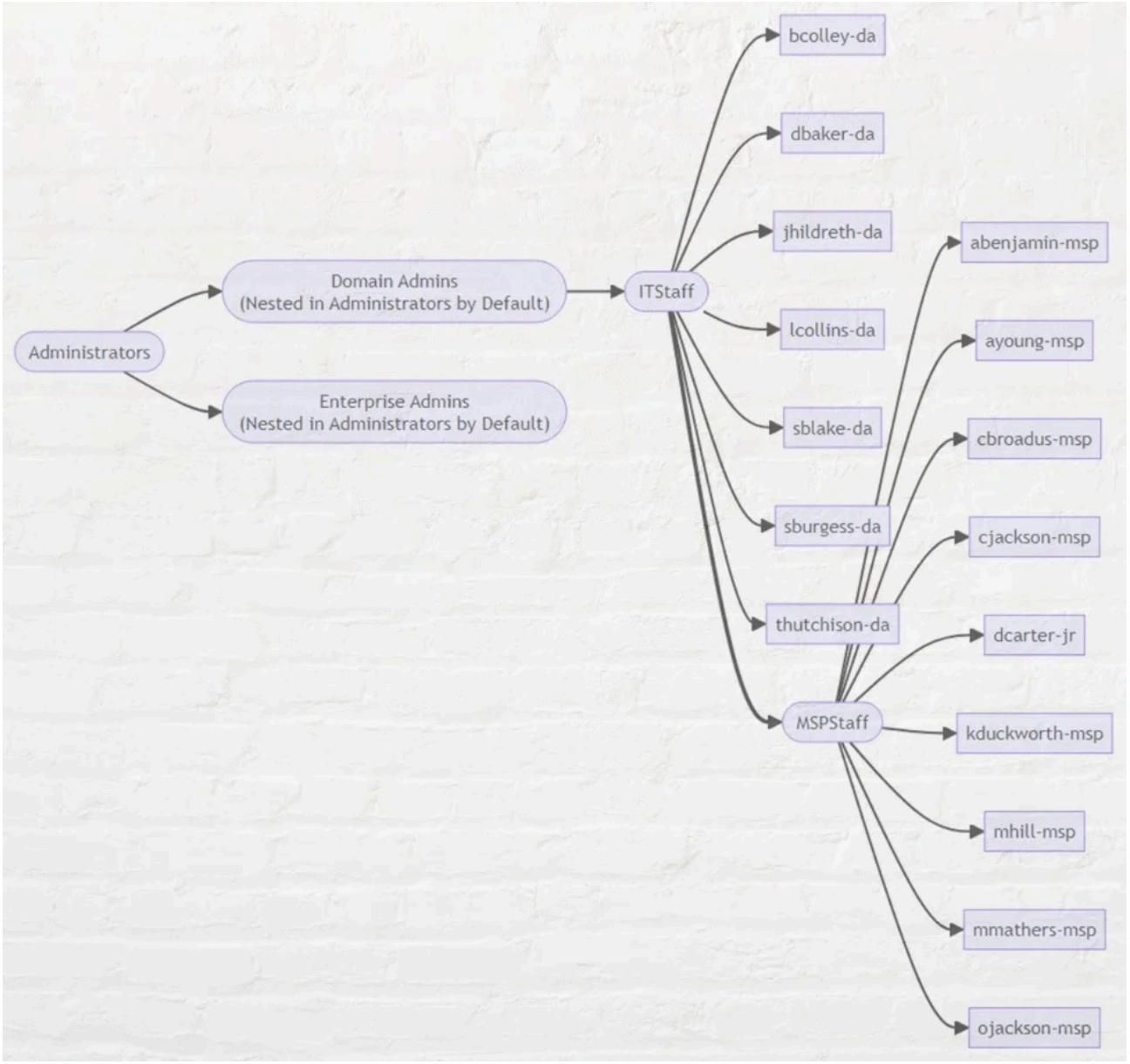


Figure 6 - Good lord how did this get here?

In general, we love to congratulate customers when they have <5 AD Admins (for small environments) or <0.05% AD Admins (for larger environments). Needless to say, this customer did not meet our recommendations.

Thankfully for this customer, this configuration was unintentional and was easy to fix. But in many customer environments, we see AD Admin numbers like this that are "intentional". 😮 Instead of doing the difficult work of least-privilege administration, "admins" are granted AD Admin privileges because it Just Works™.

How do you prevent unexpected over-privileging?

- Regularly audit your AD Admin group memberships. Automate this if possible! Any changes to the membership of these highly privileged groups should be firing off alerts in someone's face. And VERIFY your auditing takes nesting into account!

- Work to cut unnecessary AD Admin privileges from everyone. It’s much easier to remove nested groups from the AD Admin groups if no one needs AD Admin privileges to begin with.

Nested groups in Active Directory pose a challenge for organizations striving towards a more secure and streamlined IT environment. By regularly auditing AD Admin group memberships, companies can effectively combat the biggest risks associated with nested groups.

Ultimately, complexity is the enemy of security, so identifying and eliminating nested groups before they cause issues not only enhances security but simplifies administrative tasks leading to a more efficient and well-protected system.

Remember: Nesting is for the birds.



Jake Hildreth is Senior Security Consultant at Trimarc and Service Lead for Trimarc's Active Directory Security Assessment. Jake has spent the last twenty years entrenched in the world of technology and his daily mission involves bolstering the digital fortifications of major corporations, ensuring their AD security is rock solid. His is the author of Locksmith and co-author of Blue Tuxedo, tools written to ease the burden on overworked AD administrators.